

HESTIA



Matriz de permissões por perfil

FUNCIONARIO, GESTOR e ADMIN

SCRUM-46
Projeto Integrado IV
ESPM

Documento de modelagem e arquitetura

1. Objetivo

Definir o que cada perfil pode consultar ou modificar no HestIA, adotando o princípio do menor privilégio e respeitando os limites de empresa e departamento.

Esta matriz é a especificação funcional de autorização. Ela não significa que as permissões já estejam implementadas no backend.

2. Perfis existentes

O enum `PerfilUsuario`, já presente no repositório, define:

```
FUNCIONARIO  
GESTOR  
ADMIN
```

FUNCIONARIO

Usuário final da plataforma. Consulta políticas, ferramentas autorizadas e seus próprios dados. Não administra cadastros corporativos.

GESTOR

Responsável operacional por um departamento. Consulta informações do próprio departamento, acompanha seus usuários e propõe ferramentas para avaliação.

ADMIN

Responsável pela governança da empresa no HestIA. Administra cadastros, usuários, políticas, decisões sobre ferramentas e relatórios corporativos.

3. Regras de escopo

As permissões de perfil só são válidas dentro do escopo permitido:

1. Nenhum usuário pode acessar dados de outra empresa.
2. `FUNCIONARIO` acessa seus próprios dados e informações corporativas liberadas para consulta.
3. `GESTOR` acessa informações operacionais do próprio departamento e dados corporativos liberados para gestores.
4. `ADMIN` administra toda a empresa à qual pertence, mas não outras empresas.

5. O identificador de empresa recebido do cliente nunca deve ser suficiente para conceder acesso; o backend deve confrontá-lo com o usuário autenticado.
6. Mudanças de perfil, status de política, risco ou aprovação de ferramenta devem ser auditáveis.

4. Legenda

Código	Significado
SIM	Permitido no escopo do perfil
P	Permitido parcialmente ou sob condição
-	Não permitido

5. Matriz consolidada

Recurso e ação	FUNCIONARIO	GESTOR	ADMIN	Condição ou observação
Consultar dados da própria empresa	SIM	SIM	SIM	Apenas a empresa do usuário autenticado
Alterar dados da empresa	-	-	SIM	Configuração corporativa
Excluir empresa	-	-	-	Fora do MVP; exige processo administrativo excepcional
Consultar o próprio departamento	SIM	SIM	SIM	Mesmo departamento e mesma empresa
Listar departamentos da empresa	-	SIM	SIM	Gestor apenas para necessidades operacionais
Criar departamento	-	-	SIM	Empresa definida pelo contexto autenticado
Alterar departamento	-	-	SIM	Inclui responsável e hierarquia
Excluir departamento	-	-	SIM	Somente se não houver vínculos impeditivos
Consultar o próprio usuário	SIM	SIM	SIM	Nunca retornar senha
Atualizar dados pessoais próprios	P	P	P	Apenas nome e dados não administrativos definidos pelo sistema
Listar usuários do próprio departamento	-	SIM	SIM	Gestor não visualiza senhas nem dados de outros departamentos
Listar todos os usuários da empresa	-	-	SIM	Somente mesma empresa
Criar usuário	-	-	SIM	Define empresa, departamento e perfil permitidos
Alterar usuário	-	P	SIM	Gestor pode alterar dados operacionais limitados do seu departamento; não muda perfil
Ativar ou desativar usuário	-	-	SIM	Preferir desativação a exclusão física

Recurso e ação	FUNCIONARIO	GESTOR	ADMIN	Condição ou observação
Alterar perfil de usuário	-	-	SIM	Deve gerar registro de auditoria
Excluir usuário	-	-	P	Apenas quando não houver histórico; normalmente desativar
Consultar políticas ativas	SIM	SIM	SIM	Políticas da própria empresa
Consultar rascunhos de políticas	-	SIM	SIM	Para análise interna
Propor política ou alteração	-	SIM	SIM	Gestor cria proposta, não publica
Criar ou editar política oficial	-	-	SIM	Enquanto rascunho ou em revisão
Publicar, inativar ou versionar política	-	-	SIM	Mudança auditável
Excluir política	-	-	-	Preservar histórico; usar inativação/versionamento
Consultar ferramentas aprovadas	SIM	SIM	SIM	Conforme restrições corporativas
Consultar ferramentas em análise	-	SIM	SIM	Gestor acompanha propostas da própria empresa
Cadastrar ferramenta para análise	-	SIM	SIM	Status inicial EM_ANALISE
Alterar cadastro de ferramenta em análise	-	P	SIM	Gestor altera propostas sob sua responsabilidade
Avaliar risco da ferramenta	-	P	SIM	Gestor pode fornecer informações; decisão final do ADMIN
Aprovar, restringir ou bloquear ferramenta	-	-	SIM	Decisão de governança
Descontinuar ferramenta	-	-	SIM	Preserva histórico
Excluir ferramenta	-	-	-	Preferir descontinuação quando houver histórico
Consultar relatórios próprios	SIM	SIM	SIM	Quando o recurso existir
Consultar relatórios do departamento	-	SIM	SIM	Gestor limitado ao próprio departamento
Consultar relatórios corporativos	-	-	SIM	Toda a empresa, sem cruzar organizações
Consultar trilha de auditoria	-	P	SIM	Gestor vê eventos do próprio departamento
Configurar parâmetros de governança	-	-	SIM	Inclui regras corporativas futuras

6. Permissões por recurso

6.1 Empresa

Ação	FUNCIONARIO	GESTOR	ADMIN
Consultar a própria empresa	SIM	SIM	SIM
Atualizar configurações	-	-	SIM
Atualizar orçamento	-	-	SIM
Excluir	-	-	-

O endpoint atual de empresas oferece CRUD completo. Na implementação da segurança, criação, atualização e exclusão não poderão permanecer acessíveis a todos os perfis.

6.2 Departamento

Ação	FUNCIONARIO	GESTOR	ADMIN
Consultar o próprio	SIM	SIM	SIM
Listar a empresa	-	SIM	SIM
Criar	-	-	SIM
Atualizar	-	-	SIM
Excluir	-	-	SIM

O gestor não deve alterar a estrutura hierárquica sem autorização administrativa.

6.3 Usuário

Ação	FUNCIONARIO	GESTOR	ADMIN
Consultar os próprios dados	SIM	SIM	SIM
Atualizar dados pessoais permitidos	P	P	P
Listar o departamento	-	SIM	SIM
Listar a empresa	-	-	SIM
Criar	-	-	SIM
Alterar perfil	-	-	SIM
Ativar/desativar	-	-	SIM

O campo **senha** nunca pode ser retornado pela API, registrado em logs ou exposto em relatórios. Senhas devem ser armazenadas somente como hash seguro.

6.4 Política de uso

Ação	FUNCIONARIO	GESTOR	ADMIN
Consultar política ativa	SIM	SIM	SIM
Consultar rascunho	-	SIM	SIM
Propor alteração	-	SIM	SIM
Criar/editar versão oficial	-	-	SIM
Publicar ou inativar	-	-	SIM
Excluir fisicamente	-	-	-

Políticas precisam permanecer disponíveis para auditoria, mesmo quando inativas.

6.5 Ferramenta de IA

Ação	FUNCIONARIO	GESTOR	ADMIN
Consultar ferramenta aprovada	SIM	SIM	SIM
Consultar ferramenta em análise	-	SIM	SIM
Cadastrar para análise	-	SIM	SIM
Alterar proposta em análise	-	P	SIM
Informar elementos de risco	-	SIM	SIM
Definir nível de risco final	-	-	SIM
Aprovar/restringir/bloquear	-	-	SIM
Descontinuar	-	-	SIM

Esta seção utiliza os campos e estados especificados na SCRUM-52.

7. Transições autorizadas

Ferramenta de IA

```
GESTOR ou ADMIN cadastra
v
EM_ANALISE
v decisão exclusiva do ADMIN
APROVADA | RESTRITA | BLOQUEADA
v decisão exclusiva do ADMIN
DESCONTINUADA
```

Política de uso

```
GESTOR propõe ou ADMIN cria
v
RASCUNHO/EM_REVISAO
v decisão exclusiva do ADMIN
ATIVA
v decisão exclusiva do ADMIN
INATIVA ou NOVA_VERSAO
```

Os estados de rascunho e revisão ainda precisam ser harmonizados com o modelo de política existente.

8. Aplicação técnica futura

O backend deverá aplicar a matriz em duas dimensões:

```
Autorização = perfil permitido + escopo organizacional permitido
```

Exemplos:

- Não basta ser **GESTOR**; o usuário consultado precisa pertencer ao mesmo departamento.
- Não basta ser **ADMIN**; o recurso precisa pertencer à mesma empresa.
- Não basta conhecer um **id**; o serviço deve filtrar também por **empresa_id**.

Recomenda-se implementar posteriormente:

- autenticação e autorização com Spring Security;
- anotações de autorização nos casos de uso;

- filtros obrigatórios por empresa e departamento nos repositórios;
- DTOs de resposta que nunca exponham senha;
- hash de senha com algoritmo apropriado;
- respostas 403 `Forbidden` para acesso sem permissão;
- testes automatizados positivos e negativos por perfil;
- auditoria das decisões administrativas.

9. Situação atual do repositório

Na versão analisada:

- `PerfilUsuario` já contém os três perfis utilizados nesta matriz;
- os controllers de empresa, departamento, usuário e política expõem operações CRUD;
- não há dependência de Spring Security nem verificações de perfil nos endpoints;
- várias respostas retornam entidades JPA diretamente;
- `Usuario` possui o campo `senha`, que pode ser serializado se a entidade for retornada diretamente;
- não existem filtros de autorização por empresa ou departamento.

Consequentemente, esta matriz está definida, mas ainda não está implementada. A implementação de autenticação, proteção de dados e autorização deve ser planejada como tarefa técnica separada antes de disponibilizar o sistema fora de um ambiente controlado.

10. Critérios de aceite

- [SIM] Perfis existentes identificados no código.
- [SIM] Responsabilidades de `FUNCIONARIO`, `GESTOR` e `ADMIN` definidas.
- [SIM] Permissões de empresa, departamento, usuário, política e ferramenta documentadas.
- [SIM] Restrições por empresa e departamento definidas.
- [SIM] Transições administrativas identificadas.
- [SIM] Lacunas de segurança do repositório registradas.
- [SIM] Diretrizes para implementação futura documentadas.